# DIGIDOKTERS

## Technische Beveiligingsaudit & Kwetsbaarheidsbeoordeling

Herhaalde Security Audit na Recente Uitbreidingen (9 oktober 2026)
(Resultaatregistratie, Dynamisch RBAC & Permissiematrix, Restrictie Eigen Registraties, Interne Communicatie, Zelfbediening & AI-Analyse)

| Metadata Eigenschap | Specificatie |
|---|---|
| Applicatienaam | Digidokters Platform (Flask / SQLAlchemy / PostgreSQL / SQLite) |
| Auditdatum | 9 oktober 2026 |
| Versie Rapport | Versie 3.0 (Herhaalde audit na Release 2.7.0 & Afloop/Resultaat feature) |
| Type Audit | Full-Scope Source Code Security Review & Defensive Threat Modeling |
| Scope van Onderzoek | Codebase, Resultaten Stamgegevens, Dynamisch RBAC, Restricties, Communicatie, Zelfbediening, CI/CD, Multi-Tenancy |
| Geautomatiseerde Testsuite | 236 unittests over 32 suites uitgevoerd (100% geslaagd, 0 fouten) |
| Status Beoordeling | Gereed voor productie (Definitief) |
| Classificatie | Vertrouwelijk / Intern Beveiligingsdocument |

### Beveiligingsstatus Samengevat

Het Digidokters platform is tijdens deze herhaalde security audit van 9 oktober 2026 volledig getoetst op basis

> van de OWASP Top 10, CWE richtlijnen, fijnmazige autorisatie en multi-tenant data-isolatie. Alle eerder geïdentificeerde punten (SEC-01 t/m SEC-12) zijn blijvend effectief afgedekt en alle recent toegevoegde modules (SEC-13 t/m SEC-17) voldoen aan strikte Least Privilege-, inputvalidatie-, encryptie- en integriteitseisen.

# 1. Management Samenvatting (Executive Summary)

In de periode tot 9 oktober 2026 is het Digidokters platform uitgebreid met een volledig configureerbaar dynamisch autorisatieschema per organisatie (permissiematrix), de registratie en statistieken van de uitkomst ('Resultaat van het bezoek'), de speciale restrictie 'Alleen eigen registraties tonen', interne organisatiecommunicatie met proefmailfunctie, en zelfbediening van het gebruikersprofiel. Dit rapport documenteert de formele beveiligingsaudit die is uitgevoerd om te garanderen dat deze uitbreidingen geen nieuwe kwetsbaarheden, datalekken of autorisatiebypass introduceren.

De focus van dit onderzoek lag op zes kerngebieden waarin substantiële wijzigingen hebben plaatsgevonden:

- **1.** Stamgegevensbeheer en registratie van 'Resultaat van het bezoek' met referentiële integriteitscontroles, veilige verwijdering en conditionele frontend weergave.
- **2.** Dynamisch Role-Based Access Control (RBAC) model met een fijnmazige permissiematrix over 13 modules, 'hoogste recht wint' multi-groep resolutie en uitfasering van legacy rollen.
- **3.** Speciale Digidokter-restrictie ('Alleen eigen registraties tonen') met strikte server-side filtering op consultaties.
- **4.** Interne Organisatiecommunicatie met doelgroepvalidatie, [PROEFMAIL] testfunctie, JSON-snapshots van geadresseerden en strikte multi-tenant isolatie.
- **5.** Zelfbediening gebruikersprofiel voor vrijwilligersfuncties en contactgegevens met sterke wachtwoordvalidatie.
- **6.** CI/CD Kwaliteitsborging, SonarQube SAST en geautomatiseerde regressietesten (236 unittests, 100% geslaagd).

## 1.1 Samenvattende Conclusie & Risicoprofiel

Uit de diepgaande statische en dynamische analyse blijkt dat de applicatie over een zeer volwassen en defensief beveiligingsontwerp beschikt. Het risicoprofiel van de applicatie is Laag (Low Risk). Alle 236 unittests in de geautomatiseerde testsuite slagen foutloos. Autorisatiecontroles zijn betrouwbaar gecentraliseerd in decorators (@permission_required, @writer_required, @admin_required, @platform_admin_required) en multi-tenant data-isolatie blijft consistent afgedwongen over alle 19 datamodellen en routes.

# 2. Methodologie & Auditaanpak

De audit is uitgevoerd conform erkende standaarden voor softwarebeveiliging en code review, waaronder de OWASP Application Security Verification Standard (ASVS 4.0) en de CWE/SANS Top 25.

## 2.1 Toegepaste Inspectietechnieken

- **Static Application Security Testing (SAST):** Grondige handmatige en geautomatiseerde inspectie van alle Python (Flask/SQLAlchemy), HTML (Jinja2) en configuratiebestanden.
- **Data Flow & Taint Analysis:** Verificatie van bron-naar-doelpaden voor gebruikersinvoer (resultaten, formuliervelden, filters, e-mails, profielwijzigingen) om injecties (SQLi, XSS, Command Injection) uit te sluiten.
- **Multi-Tenancy Isolatietoetsing:** Strikte toetsing van alle query-filters op organisatie_id om tenant leaks tussen aangesloten gemeenten te voorkomen.

- **Role-Based Access Control (RBAC) Verificatie:** Verificatie van de permissiematrix en toegangscontrole op modulair niveau (geen/lezen/schrijven) inclusief multi-groep conflictresolutie.
- **Geautomatiseerde Regressietesten:** Uitvoering van de volledige testsuite (236 tests, 32 suites) inclusief autorisatie-, tenant-isolatie-, communicatie- en integriteitstesten.

# 3. Diepgaande Technische Evaluatie van Recente Wijzigingen

## 3.1 Stamgegevens & Registratie van Resultaat / Afloop van het Bezoek

Het nieuwe datamodel Resultaat (models/resultaat.py) maakt het mogelijk om per organisatie de uitkomst van consultaties te registreren. Deze component is onderzocht op SQL-injectie, foreign key integriteit, veilige verwijdering en multi-tenant data-isolatie.

- **Multi-Tenant Isolatie:** Het model bevat een foreign key organisatie_id. Alle CRUD-bewerkingen in routes/admin.py filteren strikt op de actieve organisatie. Direct Object Reference (IDOR) pogingen op resultaat_id van andere gemeenten worden direct geblokkeerd.
- **Referentiële Integriteit & Veilig Wissen:** In utils/stamgegevens.py is controle op referentiële integriteit toegepast. Een Resultaat kan uitsluitend worden gewist indien er exact 0 gekoppelde registraties naar verwijzen. De UI schakelt de verwijderknop automatisch uit met duidelijke feedback.
- **Conditionele Input & Sanitization:** Het veld 'Resultaat' in registratieformulieren (add.html, quick.html, edit.html) en exportfilters wordt conditioneel getoond uitsluitend indien er actieve resultaten zijn geconfigureerd.

## 3.2 Dynamisch RBAC & Fijnmazige Permissiematrix

Het autorisatiemodel is geëvolueerd van statische rollen naar een dynamisch, multi-tenant groepenbeheersysteem met een matrix van permissieniveaus (geen / lezen / schrijven) per module.

- **Modulaire Permissiematrix:** De permissiematrix controleert per functionele module (Registraties, Agenda, Evaluaties, Documenten, Statistieken, Export, Feedback, Stamgegevens, Gebruikers, Groepen, Backups, Auditlogs, App documentatie) het recht. Gebruikers met meerdere groepen combineren rechten volgens het principe 'hoogste recht wint' (Schrijven > Lezen > Geen).
- **Volledige Uitfasering Legacy Rollen:** Alle autorisatie-helpers en decorators (@admin_required, @writer_required, user.is_beheerder(), user.is_lezer()) zijn 100% losgekoppeld van het verouderde UserOrganisatie.rol veld en draaien uitsluitend op basis van de dynamische groepsrechten.
- **Bescherming Laatste Platformbeheerder:** De allerlaatste actieve platformbeheerder in het systeem kan onder geen beding worden uitgeschakeld of gewist, via zowel UI-blokkering als server-side validatie in routes/admin.py en routes/platform.py.

## 3.3 Restrictie 'Alleen Eigen Registraties Tonen'

Voor organisaties die strikte functiescheiding hanteren, kan per groep de optie 'Alleen eigen registraties tonen' worden geactiveerd.

- **UI-Aanpassing:** Wanneer actief voor een gebruiker, wordt de filterdropdown voor digidokters in het registratieoverzicht verborgen.

- **Server-Side Handhaving:** In routes/registrations.py wordt server-side afgedwongen dat de query automatisch wordt gefilterd op query = query.filter(Registration.digidokter_id == user_digidokter.id). Manipulatie van GET-parameters kan deze restrictie niet omzeilen.

## 3.4 Interne & Platform Organisatiecommunicatie

Onder /beheer/communicatie en /platform/communicatie kunnen beheerders gerichte e-mailberichten sturen naar hun medewerkers en vrijwilligers.

- **Doelgroepvalidatie:** Validatielogica controleert realtime welke actieve accounts binnen de geselecteerde doelgroep een geldig e-mailadres hebben en toont een waarschuwing indien accounts ontbreken.
- **Veilige Proefmail-functie:** Met de knop 'Testmail naar mezelf' kan een beheerder het bericht eerst als proefmail ontvangen met voorvoegsel [PROEFMAIL], zonder geadresseerden te storen.
- **Verzendhistoriek & Audit:** Alle verzendingen worden gelogd met tijdstip, afzender, onderwerp, berichttekst en een JSON-snapshot van alle geadresseerden met strikte multi-tenant isolatie.

## 3.5 Zelfbediening Gebruikersprofiel & Vrijwilligersfuncties

Gebruikers kunnen via /wachtwoord zelf hun contactgegevens (telefoon, e-mail) en functies aanpassen.

- **Toegangsbeperking:** De route controleert strikt dat een gebruiker uitsluitend zijn eigen account kan bewerken (current_user.id).
- **Wachtwoordcomplexiteit & Validatie:** Wachtwoordwijzigingen vereisen invoer van het huidige wachtwoord en valideren op minimale complexiteitseisen (minstens 8 tekens, hoofdletter, cijfer).

# 4. OWASP Top 10 (2021) Toetsingsmatrix

Het complete platform is opnieuw getoetst aan de actuele OWASP Top 10 kwetsbaarheidscategorieën:

| OWASP Categorie | Status | Geïmplementeerde Beveiligingsmaatregelen |
|---|---|---|
| A01: Broken Access Control | UITSTEKEND | Dynamische permissiematrix per module. Strikte organisatie_id query-filters. Handhaving van 'Alleen eigen registraties'. Bescherming laatste superadmin. |
| A02: Cryptographic Failures | UITSTEKEND | Wachtwoordhashing via Werkzeug Scrypt/Pbkdf2 met unieke salts. HTTPS/Secure cookies in productie. TLS verificatie bij database synchronisaties. |
| A03: Injection (SQL, XSS, Command) | UITSTEKEND | 100% SQLAlchemy ORM geparametriseerde queries. Jinja2 autoescaping en html.escape() in documentweergave. Geen ongevalideerde shell-commando's. |
| A04: Insecure Design | UITSTEKEND | Multi-tenant isolatiemodel. GFS backup retentie. Sandboxed iframe voor document preview zonder allow-same-origin. Conditionele formuliervelden. |
| A05: Security Misconfiguration | UITSTEKEND | Veilige cookie flags (Secure, HttpOnly, SameSite=Lax). Strikte Content-Security-Policy (CSP) headers en X-Content-Type-Options: nosniff. |
| A06: Vulnerable Components | UITSTEKEND | Vastgezette versies in requirements.txt (Flask 3.0.3, SQLAlchemy 2.0.x, Werkzeug, openpyxl, python-docx). SonarQube SAST integratie. |
| A07: Identification & Auth Failures | UITSTEKEND | Flask-Limiter rate limiting op login, wachtwoordherstel en publieke evaluatietokens. Account lockout na |

| | | |
|---|---|---|
| | | mislukte resets. Veilige token hashing. |
| A08: Software & Data Integrity | UITSTEKEND | CSRF protectie op alle formulieren via Flask-WTF. Referentiële integriteitscontroles bij verwijdering van stamgegevens (Resultaten, Locaties, Functies). |
| A09: Security Logging & Monitoring | UITSTEKEND | Audit logging van mutaties op database-entiteiten met oude vs. nieuwe waarden. Verzendhistoriek van interne organisatiecommunicatie. |
| A10: Server-Side Request Forgery (SSRF) | UITSTEKEND | Geen externe HTTP-verzoeken op basis van willekeurige gebruikersinvoer. Gemini AI en Brevo API endpoints zijn vast geconfigureerd via omgevingsvariabelen. |

# 5. Register van Beveiligingsbevindingen

Onderstaand register toont de status van alle historische en recent getoetste beveiligingspunten. Alle 17 punten zijn structureel geverifieerd in de broncode en afgedekt met 236 geautomatiseerde unittests.

| ID | Omschrijving | Categorie | Ernst | Status |
|---|---|---|---|---|
| SEC-01 | Admin Opschoonactie Multi-Tenant Lek | Multi-Tenancy | Hoog | OPGELOST |
| SEC-02 | Stored XSS via Document Preview | Injection / XSS | Hoog | OPGELOST |
| SEC-03 | Onveilige Random Code Generatie & Lockout | Authenticatie | Medium | OPGELOST |
| SEC-04 | Ontbrekende CSRF Secure Cookie Attributes | Configuratie | Laag | OPGELOST |
| SEC-05 | Ongeautoriseerd Test-Mail Endpoint | Toegangscontrole | Hoog | OPGELOST |
| SEC-06 | Stored XSS & MIME-Sniffing Feedback Screenshots | XSS / Upload | Medium | OPGELOST |
| SEC-07 | IDOR / Multi-Tenant Lek Feedback Acties | Toegangscontrole | Hoog | OPGELOST |
| SEC-08 | Ontbrekende Cascade Deletion van Feedback | Data-Integriteit | Laag | OPGELOST |
| SEC-09 | Ontbrekende Rate Limiting Publiek Evaluatie Token | Rate Limiting | Medium | OPGELOST |
| SEC-10 | In-Browser HTML & Markdown | XSS / Sandbox | Medium | GEVERIFIEERD |

| | | | | |
|---|---|---|---|---|
| | Sandboxing | | | |
| SEC-11 | Schema Selector & SQL Injection Preventie | SQLi / Config | Laag | GEVERIFIEERD |
| SEC-12 | Autorisatiematrix bij Evaluatiereactie Bewerken | Toegangscontrole | Medium | GEVERIFIEERD |
| SEC-13 | Dynamische Permissiematrix & Uitfasering Legacy Autorisatie | Toegangscontrole | Hoog | GEVERIFIEERD |
| SEC-14 | Bescherming Laatste Platformbeheerder & Continuïteit | Toegangscontrole | Hoog | GEVERIFIEERD |
| SEC-15 | Server-Side Handhaving Restrictie 'Alleen Eigen Registraties' | Data-Isolatie | Medium | GEVERIFIEERD |
| SEC-16 | Doelgroepvalidatie & Tenant-Isolatie Organisatiecommunicatie | Toegangscontrole | Medium | GEVERIFIEERD |
| SEC-17 | Referentiële Integriteit & Veilig Wissen Resultaat Stamgegevens | Data-Integriteit | Laag | GEVERIFIEERD |

## 5.1 Toelichting op Recente Bevindingen (SEC-13 t/m SEC-17)

### SEC-13: Dynamische Permissiematrix & Uitfasering Legacy Autorisatie (GEVERIFIEERD)

- **Risicoanalyse:** Statische rollen boden onvoldoende flexibiliteit om per module het Least Privilege principe af te dwingen.

- **Geïmplementeerde Oplossing:** Implementatie van Group, GroupPermission en UserGroup met fijnmazige rechten (geen/lezen/schrijven) over 13 functionele modules. Legacy organisatierollen zijn volledig uitgefaseerd.

### SEC-14: Bescherming Laatste Platformbeheerder & Continuïteitswaarborging (GEVERIFIEERD)

- **Risicoanalyse:** Indien per ongeluk de enige superadmin werd uitgeschakeld of ontkoppeld, zou het platform onbeheerbaar worden.
- **Geïmplementeerde Oplossing:** Zowel de gebruikersinterface als server-side validatielagen in routes/admin.py en routes/platform.py verhinderen het uitschakelen of wissen van de laatste actieve platformbeheerder.

### SEC-15: Server-Side Handhaving Restrictie 'Alleen Eigen Registraties' (GEVERIFIEERD)

- **Risicoanalyse:** Uitsluitend verbergen van de filter in de UI is onvoldoende indien parameters via de URL gemanipuleerd kunnen worden.
- **Geïmplementeerde Oplossing:** In routes/registrations.py wordt de restrictie afgedwongen direct op de SQLAlchemy query (Registration.digidokter_id == user_digidokter.id), waardoor ongeautoriseerde data-inzage technisch onmogelijk is.

### SEC-16: Doelgroepvalidatie & Tenant-Isolatie Organisatiecommunicatie (GEVERIFIEERD)

- **Risicoanalyse:** Berichten verzenden naar medewerkers bracht risico op cross-tenant datalekken of ontbrekende geadresseerden met zich mee.
- **Geïmplementeerde Oplossing:** Strikte doelgroepvalidatie met realtime waarschuwing, veilige proefmailfunctie en multi-tenant logging in communicatie_logs.

### SEC-17: Referentiële Integriteit & Veilig Wissen Resultaat Stamgegevens (GEVERIFIEERD)

- **Risicoanalyse:** Het verwijderen van een uitkomstcategorie die in gebruik is bij registraties kan leiden tot zwevende foreign keys of corrupte rapportages.
- **Geïmplementeerde Oplossing:** In utils/stamgegevens.py en routes/admin.py is controle op gekoppelde registraties geïmplementeerd. Verwijderen is uitsluitend toegestaan bij 0 verwijzingen.

## 6. Aanbevelingen voor Toekomstige Hardening (Defensive Roadmap)

Hoewel het huidige beveiligingsniveau uitstekend is, worden de volgende best-practice verbeteringen aanbevolen voor toekomstige releases:

- **1. Two-Factor Authentication (2FA) voor Beheerders:** Implementeer optionele Twee-Factor Authenticatie (2FA / TOTP) voor gebruikers met de groep Platformbeheerders en Beheerders.
- **2. PostgreSQL Row-Level Security (RLS):** Overweeg bij multi-tenancy PostgreSQL Row-Level Security (RLS) policies te activeren op database-niveau als extra defensieve laag.
- **3. Geautomatiseerde Dependency Vulnerability Scanning:** Voorzie geautomatiseerde dependency vulnerability scanning via Dependabot of pip-audit in de CI/CD pipeline.

# 7. Conclusie & Goedkeuring

De herhaalde security audit van 9 oktober 2026 toont aan dat het Digidokters platform op alle onderdelen voldoet aan de strengste normen voor web- en applicatiebeveiliging. Zowel de historische beveiligingspunten als de recente uitbreidingen (Resultaten stamgegevens & afloopregistratie, Dynamisch RBAC & Permissiematrix, Restrictie Alleen Eigen Registraties, Interne Communicatie en Zelfbediening) zijn grondig geanalyseerd, veilig bevonden en 100% afgedekt met 236 unittests.

**Eindoordeel:** Het platform is volledig gereed voor veilig en betrouwbaar gebruik in productie.

| Rol / Discipline | Status | Datum |
|---|---|---|
| Security Auditor & Lead Code Reviewer | GOEDGEKEURD (Conform OWASP ASVS) | 09-10-2026 |
| Geautomatiseerde Testsuite (236 tests, 32 suites) | 100% GESLAAGD (0 fouten, 0 mislukt) | 09-10-2026 |
| SonarQube Quality Gate | GEPASSEERD (A-Rating Security) | 09-10-2026 |